# SQL Injection



# What are some bad input strings?

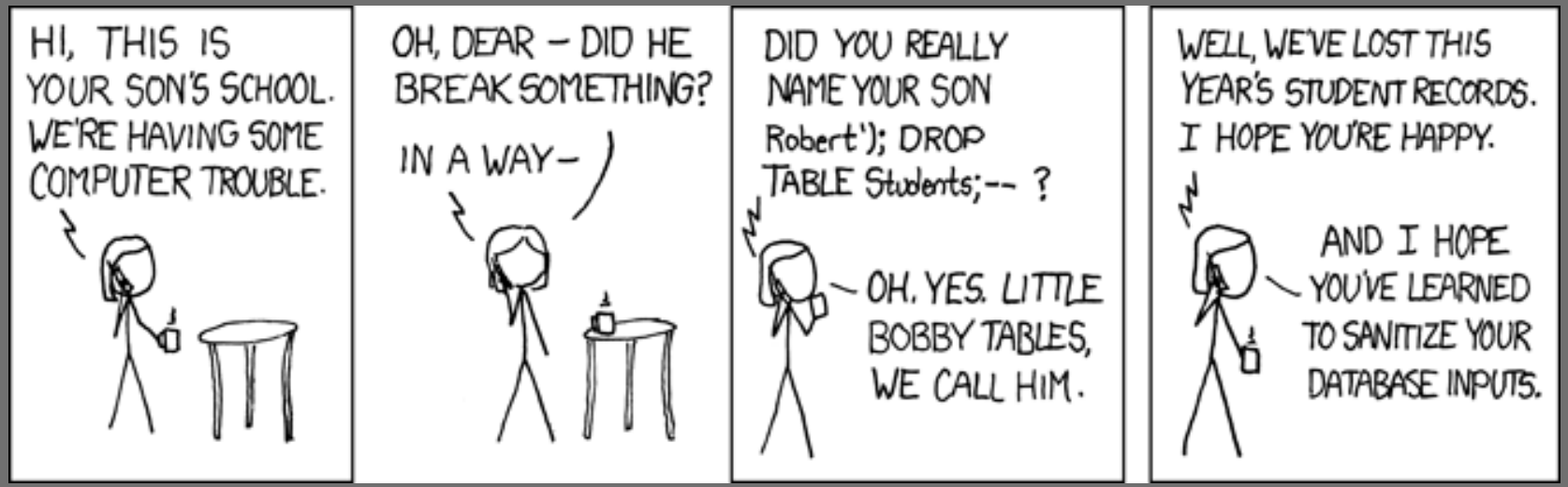
```
sId = getRequestString("StudentID");
String query = "SELECT first, last FROM Student WHERE id = " + sId;
Statement stmt = connection.createStatement(query);
```

Satisfy WHERE clause: `"1234 OR 1=1"`

Expose implementation: `"1 AND userid IS NULL"`

Retrieve arbitrary data: `"1234 UNION SELECT id, password FROM Student"`

Cause destructive behavior: `"1234; DROP TABLE Student"`


HI, THIS IS YOUR SON'S SCHOOL. WE'RE HAVING SOME COMPUTER TROUBLE.
OH, DEAR – DID HE BREAK SOMETHING?
IN A WAY–
DID YOU REALLY NAME YOUR SON Robert'); DROP TABLE Students;-- ?
OH. YES. LITTLE BOBBY TABLES, WE CALL HIM.
WELL, WE'VE LOST THIS YEAR'S STUDENT RECORDS. I HOPE YOU'RE HAPPY.
AND I HOPE YOU'VE LEARNED TO SANITIZE YOUR DATABASE INPUTS.

xkcd.com/327/

# Construct valid SQL

- Validate input used in SQL command strings
  - E.g., numeric input only contains digits
- Construct via parameterized APIs

# Demo: Parameterized API

- Show example Java code

# Don’t expose DB structure

- Catch & handle all DB exceptions

# Limit what bad SQL can do

- Use view- or function-based API
- Minimize user privileges